



OASIS Security Report

Session Management Issues Security Analysis

Date: 2026-06-11 10:42:46 — **Model:** mistral:latest

Vulnerability: Session Management Issues

Project: clean_contracts

Analysis root: `../clean`

Table of contents

▢ Summary

▢ Statistics

▢ Files

▢ Detailed analysis

▢ Assistant

△ Errors & notes

Summary

Analyzed **2** file(s) for Session Management Issues.

[Return to table of contents](#)

Statistics

Files analyzed: 2 **Total findings:** 2

Critical

(

0

High		0
Medium		2
Low		0

[Return to table of contents](#)

Files

File	Similarity
<code>/work/project/dataset/clean/modifier_reentrancy_fixed.sol</code>	0.589
<code>/work/project/dataset/clean/simple_dao_fixed.sol</code>	0.555

[Return to table of contents](#)

Detailed analysis

File 1: /work/project/dataset/clean/modifier_reentrancy_fixed.sol

Similarity score: 0.589

Source lines: 1-42

► Finding 1.1: Session Management Issue found (Medium)

Vulnerable code

```
`requires(tokenBalance[msg.sender] == 0); _;`
```

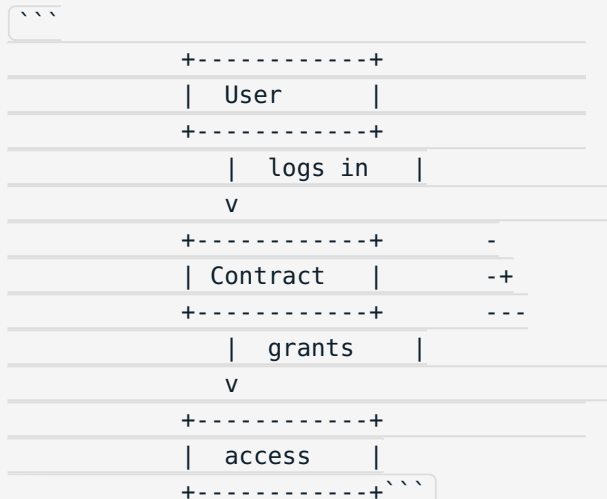
Explanation

The contract's state is dependant on the user's session (tokenBalance), but there is no session timeout set.

Impact

Account takeover and unauthorized access to user accounts

Execution path



Exploitation steps

- User logs in to contract
- Attacker intercepts and reuses user's session

Conditions

Attacker has network access to the contract

Remediation

Implement proper timeout settings for user sessions

File 2: /work/project/dataset/clean/simple_dao_fixed.sol

Similarity score: 0.555

Source lines: 1-34

► Finding 2.1: Vulnerability found (Medium)

Vulnerable code

```
function withdraw(uint amount)
```

Explanation

The 'withdraw' function does not check for the existence of an active session, making it susceptible to session hijacking.

Impact

Account takeover and unauthorized access to user accounts

Entry point

function withdraw()

Execution path

```
```  
1. User authenticates and starts a session
2. Attacker intercepts the session token or steals it
3. Attacker calls the 'withdraw' function using the stolen session token
4. The contract executes the withdrawal without any checks, allowing the
attacker to withdraw funds```
```

#### Parameters

amount

#### Exploitation steps

- Intercept or steal session token
- Call 'withdraw' function with the stolen session token

#### Conditions

Attacker can intercept or obtain user's session token

#### Remediation

Implement secure session handling, such as checking for an active session before executing sensitive functions.

## Secure example

```
'''
function withdraw(uint amount) public requires (activeSession) {
 if (credit[msg.sender]>= amount && activeSession[msg.sender]) {
 credit[msg.sender]-=amount;
 require(msg.sender.call.value(amount)());
 }
}
'''
```

[Return to table of contents](#)

## Assistant (triage / codebase)

In the OASIS dashboard (JSON report preview), use the chat below to triage findings, exploitation paths, and remediation. Select file, chunk, and finding to narrow context when needed.

[Return to table of contents](#)

## Errors & Notes

No file-level errors were recorded.

[Return to table of contents](#)